

Third-party security risk assessment

PeopleDesk | Northstar Flow | 8 September 2026 | Version 1.0

Prepared by: Shahzeb Ali

Independent GRC Portfolio Project

Independent portfolio exercise based on fictional organizations. No real vendor assessment, client engagement or assurance review took place.

Recommendation: Conditional Approval

Recommend renewal only after four High findings are treated, evidence is reviewed and the remaining risk is accepted. The current decision is pending; this report does not authorize renewal or continued use. Four Medium findings need dated commitments and interim acceptance. The new Entra API remains disabled until its separate activation gate passes.

Scope and inherent exposure

PeopleDesk is the fictional HR SaaS already identified as A-009 in Project 1. This renewal review covers personal information, employment and leave records, payroll-related data, manager/employee accounts and a proposed Entra integration for all 50 employees. External hosting and subprocessors are included; direct Northstar administrator access is not assumed.

Sensitive records and workforce-wide exposure make the inherent tier High before controls. Moderate operational dependency does not offset that exposure. Remediation does not reduce the inherent tier.

Finding	Score / severity	Decision requirement
F-001 Privileged MFA exception	16 / High	Before renewal
F-002 Incomplete subprocessor assurance	8 / Medium	Dated commitment
F-003 Recovery capability unsubstantiated	12 / High	Before renewal
F-004 Annual privilege review	8 / Medium	Dated commitment
F-005 Unclear incident notice terms	12 / High	Before renewal
F-006 Raw HR data in test	12 / High	Before renewal
F-007 Entra API permissions unclear	8 / Medium	Before API activation
F-008 Backup deletion / exit unclear	6 / Medium	Dated commitment

Snapshot: 8 findings, comprising 4 High and 4 Medium. No remediation is verified. Current scores are scenario judgments with low evidential confidence.

Executive recommendation and conditions

Management summary | continued

Four High findings must close before renewal

By the scenario decision date of 8 October 2026, require complete privileged MFA coverage (F-001), a demonstrated HR recovery capability (F-003), clear incident-notification obligations (F-005), and removal of raw employee data from test environments (F-006). Evidence criteria and accountable vendor/Northstar roles are defined in the workbook. A promise to remediate is insufficient.

For each gate, the Security Lead reviews the evidence, the risk owner reassesses and accepts the remaining risk, and the CTO signs the renewal decision. Require a score below 10 and proof that the specified failure path is addressed. A task marked complete is not evidence of effectiveness.

Medium commitments and integration boundary

Before renewal, agree actions due 7 November 2026 for subprocessor assurance (F-002), quarterly privileged reviews (F-004), integration permissions (F-007), and backup deletion/exit (F-008). Obtain owner acceptance of interim exposure and review progress weekly. Keep the new API disabled until exact scopes, consent, credentials and revocation tests pass; renewal of existing HR use does not authorize that integration.

Recovery and contract requirements

PeopleDesk's simulated RTO and RPO claims are both 24 hours. Northstar's People Lead must validate this HR-specific tolerance; the core application's 8-hour RTO from Project 1 is not automatically inherited. A lower impact rating requires a successful restore plus a tested manual payroll workaround that limits business harm. Meeting a 24-hour technical RTO alone does not justify lowering impact.

Agree processing purposes and locations, subprocessor and material-change obligations, evidence access, recovery objectives, data return/deletion and cooperation duties. For F-005, propose initial notice within 24 hours of awareness of an incident affecting Northstar data or service, followed by useful updates and named contacts. This is a proposed contractual target, not a statutory deadline. Relevant jurisdictions and transfer obligations require contextual internal review.

If conditions are not met

Defer renewal and escalate to the CTO. Existing use requires a separate, documented continuity decision with interim controls and expiry within 30 days; none is assumed here. Without that decision, prepare a controlled export/exit rather than leaving a silent exception. Reassess annually and after incidents, material supplier changes, new processing scope or assurance expiry.

Independent portfolio exercise based on fictional organizations. No real vendor assessment, client engagement or assurance review took place.

Method, evidence and limitations

Separate the two risk decisions

Inherent relationship tier uses the maximum exposure rating: 1 Low, 2 Moderate, 3 High, 4 Critical. The workbook defines triggers before vendor responses are considered. This is an exposure tier, not a questionnaire pass rate. Current finding severity uses a separate 5 × 5 likelihood/impact model over 12 months, with the highest credible confidentiality, integrity, availability or business consequence.

Risk score = Likelihood × Impact. Bands are Low 1–4, Medium 5–9, High 10–16 and Critical 17–25. These are portfolio methodology choices, not ISO-prescribed bands. Scores of 10 or more require treatment before renewal; lower scores still need an accountable decision. The vendor findings remain separate from Project 1's enterprise register and should not be added into a total loss number.

Questionnaire → evidence → findings

The workbook contains 48 questions across 11 domains and 24 evidence topics. Each question links to an evidence request; every finding links back to the relevant topics. All response and received/review states are simulated narratives. No real vendor documents, certificate, assurance report, test result or configuration export was obtained or fabricated.

For example, a claimed certificate may have a plausibly relevant scope in the scenario, but its authenticity and coverage are unverified. The MFA exception is a known scenario gap; absent recovery reports are an evidence gap, not proof of failed backups. A real reviewer would validate identity, scope, freshness, completeness, exceptions and operational samples before crediting a control.

Projected risk is conditional

The proposed targets range from 3 to 8 and require successful remediation and evidence review. They are not achieved residual risk. Current scores give credit only to stated scenario safeguards and retain low evidential confidence. F-005's impact reduction concerns the additional harm from late notification, not the underlying incident; F-003 requires both recovery evidence and a tested workaround.

Supplier-risk connection and sources

The workbook paraphrases five relevant Annex A concepts: A.5.19 vendor safeguards, A.5.20 supplier commitments, A.5.21 fourth-party dependencies, A.5.22 ongoing oversight and A.5.23 cloud responsibilities. This selected mapping is neither a complete SoA nor an ISO certification audit. Sources accessed 8 September 2026.

ISO/IEC 27001:2022 — official overview

Enterprise Singapore — authorized ISO/IEC 27002:2022 adoption preview (contents used to check identifiers)

Independent portfolio exercise based on fictional organizations. No real vendor assessment, client engagement or assurance review took place.